Secure Audit Hub

AI Integration Report — Migration from Anthropic (Claude) to Google AI Studio (Gemini)

Project	Secure Audit Hub / Tool (EDR Platform)
Component	FastAPI backend (Render) + services layer
Scope of this report	AI Analysis feature build-out (Gemini)
Prepared for	Flew (Intern #2130)

1. Overview

The Secure Audit Hub EDR platform previously used Anthropic's Claude API for AI-assisted alert analysis. This work replaced that integration with Google AI Studio (Gemini) and then built out a full AI Analysis feature set on top of it: automatic alert explanations, risk-aware recommendations, MITRE ATT&CK; technique explanations, threat-intel-grounded analysis (VirusTotal, MalwareBazaar, URLhaus, and related providers), a file/malware scanning endpoint, AI-generated incident reports, and a conversational AI chat endpoint for analysts.

2. Migration: Anthropic to Google AI Studio (Gemini)

All references to Anthropic's API were removed and replaced with Gemini equivalents:

- **config.py**: `ANTHROPIC_API_KEY` replaced with `GEMINI_API_KEY`; default model changed to `gemini-2.5-flash`.
- **main.py**: config imports, fallback defaults, and the `AIAnalysisService` instantiation all updated to use the Gemini key and model instead of the Anthropic ones.
- **.env.example**: added `GEMINI_API_KEY`, `AI_ANALYSIS_ENABLED`, and `AI_ANALYSIS_MODEL` variables (with a link to get a free API key from Google AI Studio).
- **services/ai_analysis.py**: rebuilt from scratch as a new `AIAnalysisService` class that calls the Gemini `generateContent` REST endpoint directly via `requests` (no extra SDK dependency needed).

3. New AI Analysis Feature

3.1 Core alert analysis

For any alert, Gemini now returns a structured JSON analysis with four fields: a plain-English **summary** of what happened and why it matters, the **likely intent** behind the activity, a concrete **recommended action**, and a **confidence** level (low / medium / high). The service fails safe: if the API key is missing, disabled, or a request errors out, it returns a clearly-labelled fallback message instead of crashing the platform.

3.2 Threat-intel-grounded analysis (VirusTotal, malware, URL/IOC enrichment)

Before an alert is sent to Gemini, an IOC extractor scans its title, description, and details for IP addresses, file hashes, URLs, and domains. Each indicator found is looked up through the existing `threat_intel.py` pipeline, which already integrates VirusTotal, MalwareBazaar, URLhaus, AbuseIPDB, OTX, and GreyNoise. The verdicts (e.g. "12/70 VirusTotal engines flagged this as malicious") are injected into the Gemini prompt, so the AI's explanation is grounded in real provider data instead of guessing from the alert text alone.

3.3 File / malware scanning

A new endpoint, `POST /api/tools/file-scan`, accepts a file upload, computes its SHA-256 and MD5 hashes locally, and checks the hash against VirusTotal and MalwareBazaar. This is hash/reputation-based detection (is this a known piece of malware), not sandboxed execution analysis.

3.4 MITRE ATT&CK explanation

Every alert analysis now also includes an **ai_mitre_explanation** field: 1-2 plain-English sentences explaining what the alert's MITRE ATT&CK technique means and why it is relevant to that specific alert.

3.5 Automatic "Alert to Gemini" pipeline

New columns were added to the `Alert` database table (`ai_summary`, `ai_likely_intent`, `ai_recommended_action`, `ai_confidence`, `ai_mitre_explanation`, `ai_analyzed_at`), with an automatic startup migration so existing SQLite databases pick up the new columns without needing to be recreated. The first time an analyst opens an alert (`GET /api/alerts/{alert_id}`), the platform automatically runs the Gemini analysis and caches the result — no manual step required. `POST /api/alerts/{alert_id}/ai-analysis` remains available to force a fresh re-analysis on demand.

3.6 Dashboard AI card (backend data)

A new endpoint, `GET /api/dashboard/ai-card`, returns aggregated data for a future frontend "AI Insights" card: whether AI analysis is enabled, total alert count, how many alerts have been AI-analyzed, and the top 5 AI-recommended actions across open critical/high-severity alerts. *Note: the visual dashboard card itself is a frontend task and was not built as part of this backend work, since the frontend repository has not yet been shared.*

3.7 AI-generated incident reports

A new endpoint, `POST /api/correlation/incidents/{incident_id}/ai-report`, takes a correlated incident (built from the existing correlation engine's attack-chain and matched-pattern data) and asks Gemini to produce a management-facing report with an executive summary, a timeline narrative, a best-guess root cause, business impact, and up to five recommended next steps.

3.8 AI chat for analysts

A new endpoint, `POST /api/ai-chat`, lets an analyst ask a free-form question, optionally grounded in a specific alert or incident (via `alert_id` or `incident_id` in the request body). Gemini answers in plain text using that context when relevant.

4. New / Changed API Endpoints

Method & Path	Purpose
GET /api/alerts/{alert_id}	Auto-triggers Gemini analysis on first view; returns cached AI fields
POST /api/alerts/{alert_id}/ai-analysis	Force a fresh Gemini analysis + IOC enrichment
POST /api/tools/file-scan	Upload a file; hash it and check VirusTotal / MalwareBazaar
GET /api/dashboard/ai-card	Aggregated AI stats + top recommendations for a dashboard card
POST /api/correlation/incidents/{id}/ai-report	AI-generated narrative incident report
POST /api/ai-chat	Free-form AI chat, optionally grounded in an alert/incident
GET /api/threat-intel/lookup	Existing endpoint (unchanged) for direct IOC lookups

5. Task Board Status

Task	Priority	Status
Gemini API integration	High	Done (needs GEMINI_API_KEY set on Render)
Alert -> Gemini pipeline	High	Done (automatic on first alert view)
AI Summary	High	Done (returned on every alert)
Dashboard AI Card	High	Backend data ready; frontend widget pending
Threat Intel + AI	Medium	Done
MITRE Explanation	Medium	Done
AI Incident Report	Low	Done
AI Chat	Low	Done

6. Database Changes

Six new nullable columns were added to the `alerts` table: `ai_summary`, `ai_likely_intent`, `ai_recommended_action`, `ai_confidence`, `ai_mitre_explanation`, and `ai_analyzed_at`. A startup routine checks for these columns via `PRAGMA table_info` and adds any that are missing, so the existing production SQLite database does not need to be recreated or manually migrated.

7. Next Steps

- Get a free Gemini API key from Google AI Studio and set `GEMINI_API_KEY` in Render's environment variables.
- Redeploy the backend so the new endpoints and DB migration take effect.

- Share the frontend (Netlify) repository so the Dashboard AI Card, alert AI summary display, incident report view, and AI chat UI can be built against the new endpoints.
- Test each endpoint (alert view, file-scan, incident ai-report, ai-chat) end-to-end with a real API key.
